

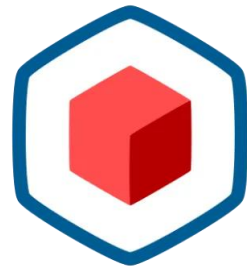
Kata4.0与CoCo机密容器

李亚南、马丁

蚂蚁集团、阿里云

2025/11/15





**CONFIDENTIAL
CONTAINERS**



katacontainers



李亚南

嘉宾职位：高级软件开发工程师

个人简介：李亚南是蚂蚁集团云原生容器基础设施团队的软件开发工程师，目前专注于安全容器 Kata 和 CoCo（机密计算）等开源项目。同时他也是 Kata Containers 社区的 Maintainer，负责 runtime(rs)、kata-agent 等核心组件的开发与维护工作。



马丁

嘉宾职位：阿里云高级开发工程师

个人简介：目前主要从事**机密计算**生态、技术方案及开源社区标准化建设，目前是Confidential Containers云原生机密容器社区Maintainer之一，也是Initdata、AAEL等远程证明标准化格式定制者，同时也是IETF RATS COSERV标准化定制者之一。

CONTENT

目录

01 [Kata Containers 4.0: Runtime-rs](#)

02 [Runtime-rs is The Future](#)

03 [The Next Layer of Cloud Security](#)

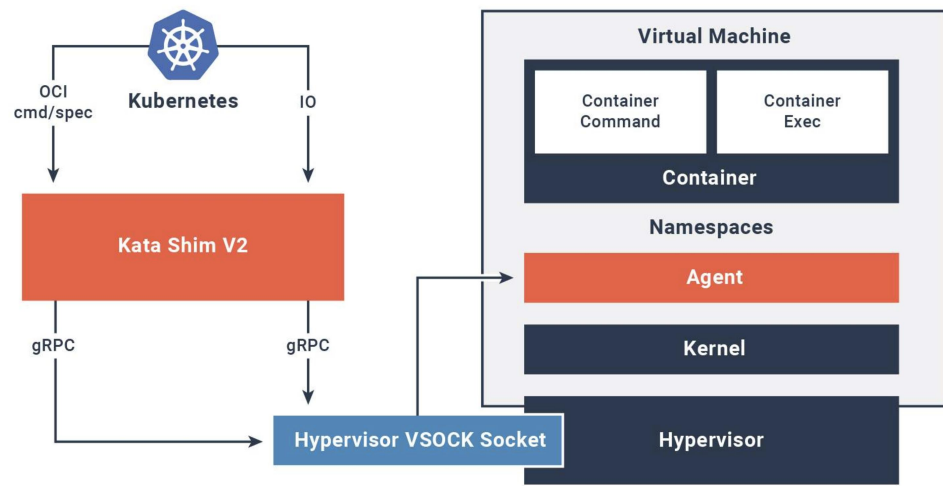
04 [Full CoCo Support in Runtime-rs](#)

Kata Containers

- Kata Containers

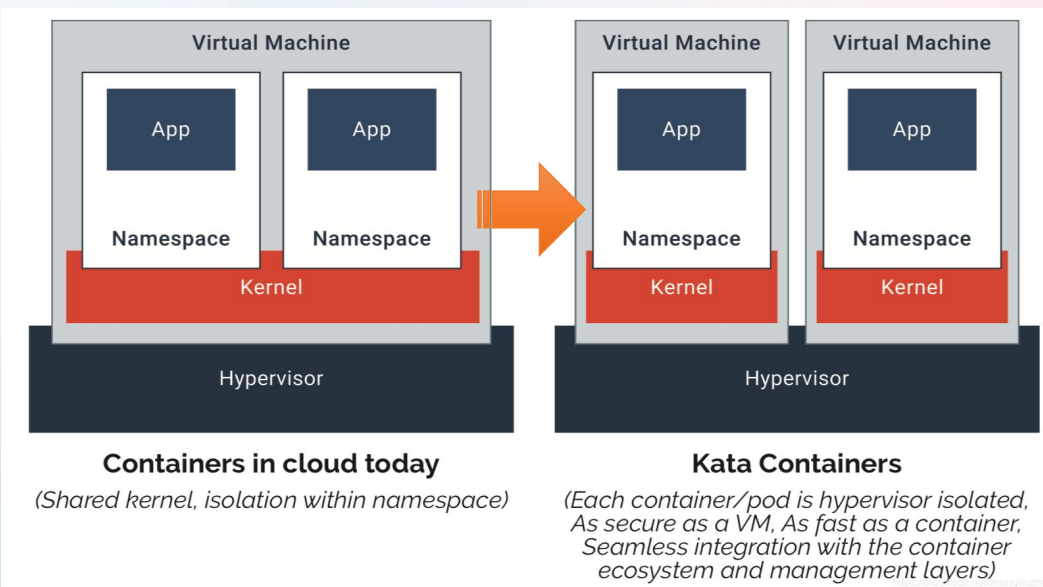
- OpenInfra 基金会的顶级开源项目
- 解决传统容器的安全和隔离缺陷
- 结合容器的轻量级特性与虚拟机的强大隔离能力

katacontainers | Kata Shim V2



- 解决的关键问题

- 传统容器的脆弱性：共享内核 安全边界模糊
- 性能与安全的权衡：虚拟机 VS 容器

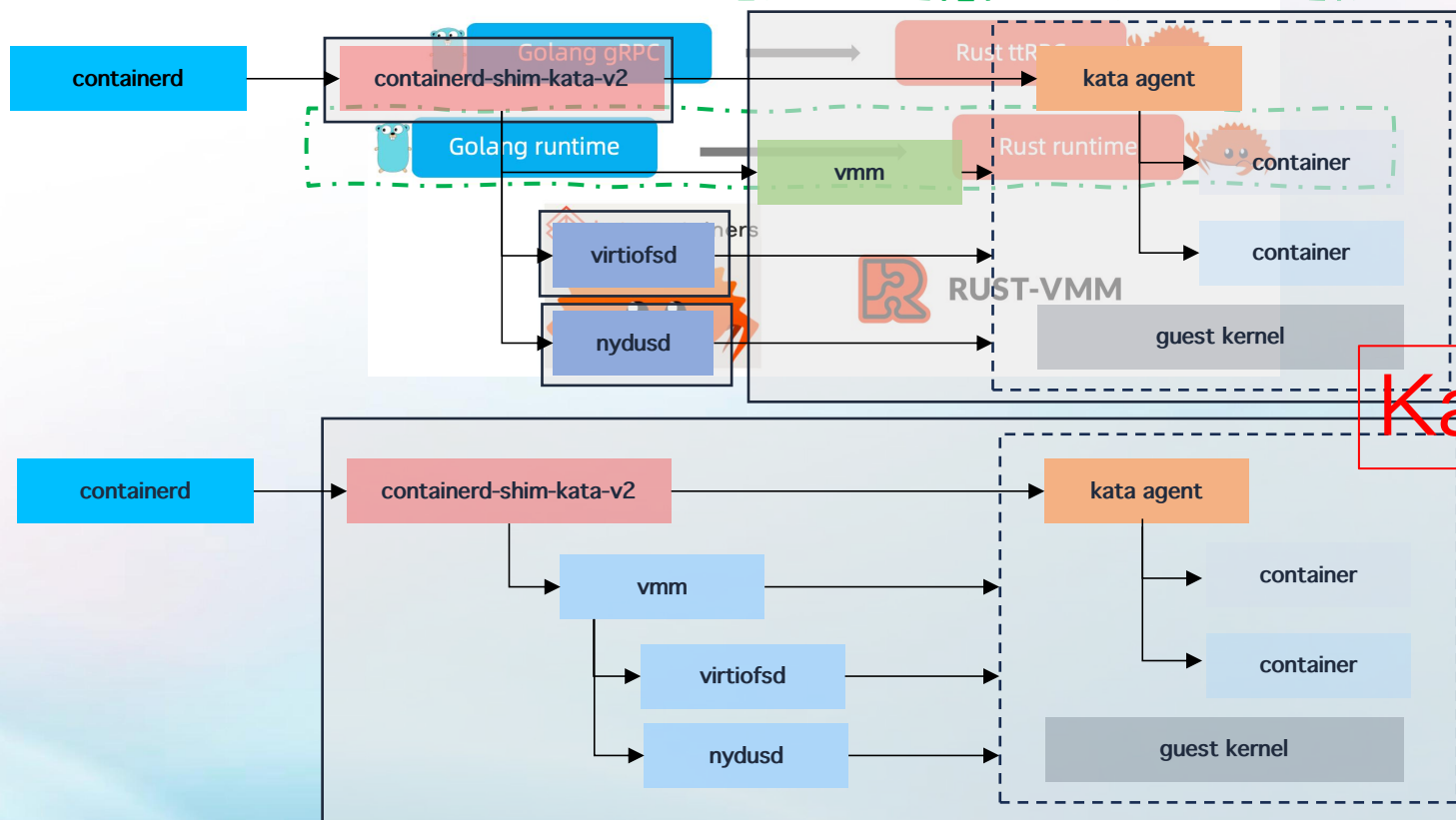


Kata Containers

架构演进 -> Runtime-rs

Kata-agent RssAnon: 11MB -> 300KB (10x improvement)

Runtime-rs RssAnon Drop ???



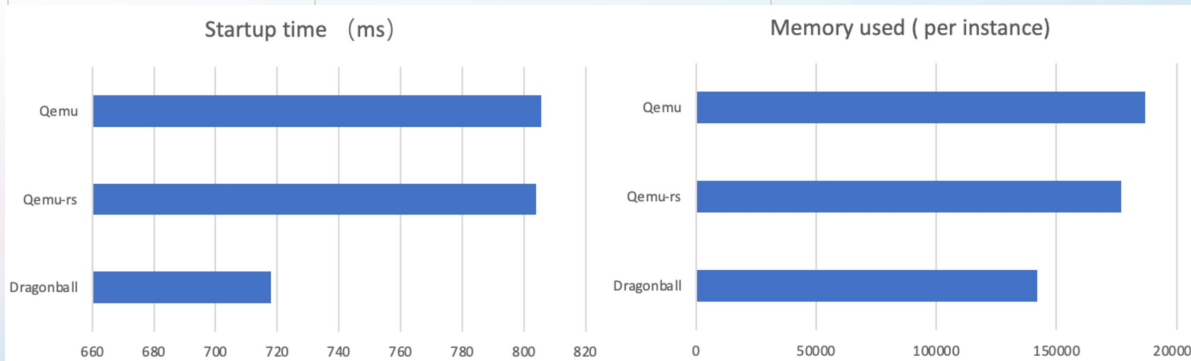
Runtime-rs is the Future

Startup & Memory Usage Per Kata Pod

Metric	Startup time(ms)	Memory used(kb)
Qemu	805.577514	186853.6
Qemu-rs	803.950059	176848.56
Dragonball	718.061872 (718 ms)	141944.64 (138MB)

Startup: ~10.9% vs QEMU

Memory: ~24.0% vs QEMU



Builtin Dragonball VMM

- Kata release 3.17 with default_vcpu = 1, default_memory=2G
- `ctr run --runtime io.containerd.kata.v2 --rm -t alpine:latest "$CONTAINER_NAME" /bin/sh -c "uname -r"`

Runtime-rs is the Future

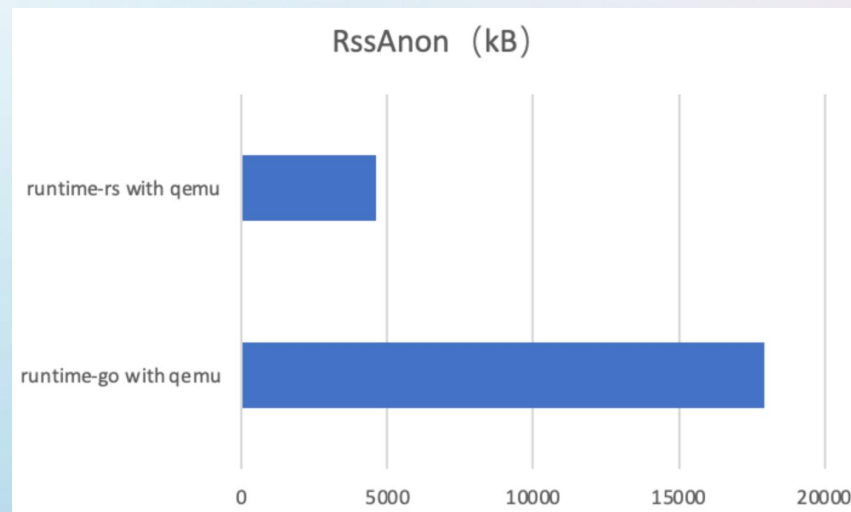
RssAnon Memory

- RssAnon (Resident Set Size – Anonymous):
 - 当前驻留在 RAM 中匿名内存（非文件支持内存）的大小
 - 衡量进程实际内存使用量的一个良好且可靠的指标
 - 测量 shim-kata-v2 进程所使用的 RssAnon

- Runtime-rs RssAnon Drop:
 - 17.5MB → 4.49MB (3.9x improvement)

```
- Kata release 3.17 with default_vcpu = 1, default_memory=2G
- nerdctl run --runtime io.containerd.kata.v2 -ti --rm --net=none --name=qemu-rs-test
  ${IMAGE}
- cat /proc/${SHIM_PROCESS_PID}/status |grep RssAnon
```

containerd-shim-kata-v2	RssAnon
runtime-rs with qemu (qemu-rs)	4596 kB
runtime-go with qemu	17928 kB

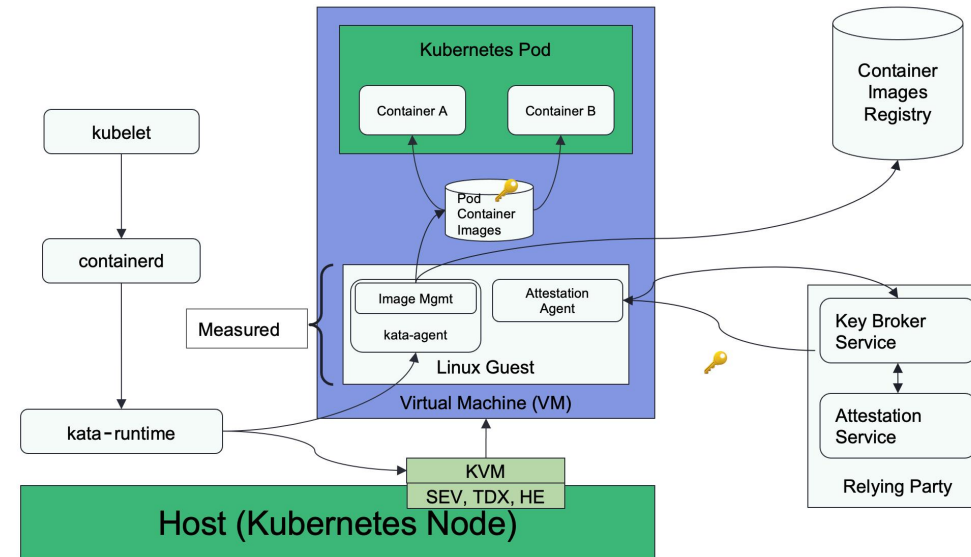


The Next Layer of Cloud Security

Confidential Containers

- 一个 CNCF 沙箱项目 (2022 年)
- 旨在解决传统安全措施未能保护在用数据 (正在内存中处理的数据) 的问题
- 这是一个构建在 Kata Containers 之上的机密计算解决方案
- 它通过一整套安全加固技术来扩展 Kata, 从而在云原生环境中实现机密计算

Confidential Containers - v1



The Next Layer of Cloud Security

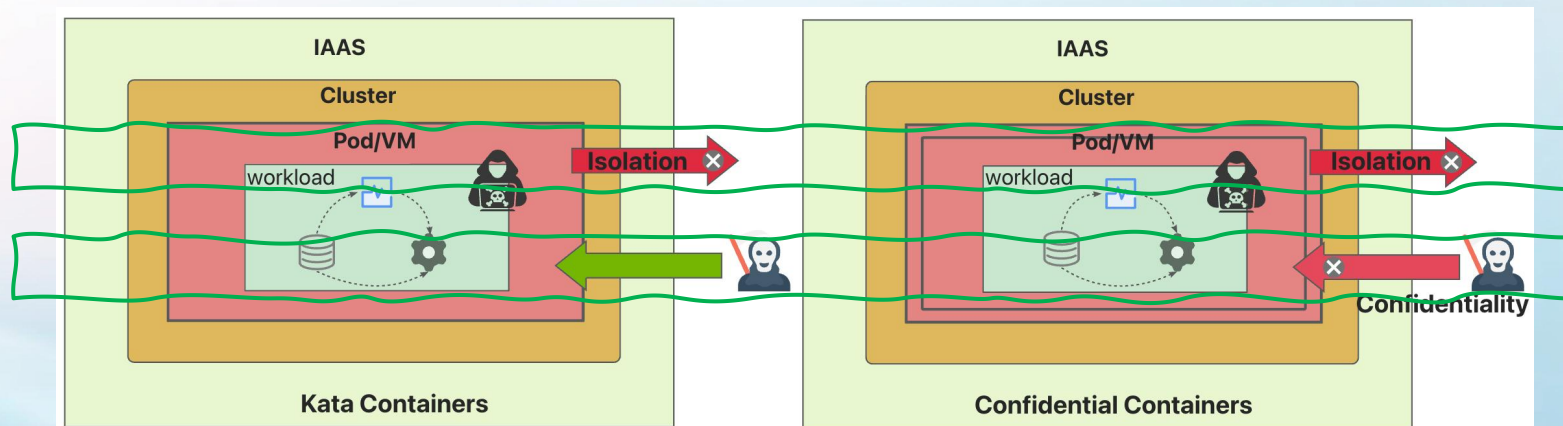
Foundation & Evolution

Kata 作为基础 (Kata as Foundation)

- 提供隔离的运行时基础，在带有专用内核的独立 VM 中运行 Pod/容器。
- 防止容器逃逸，并确保故障隔离等。
- 保护宿主机和集群内的其他容器免受破坏

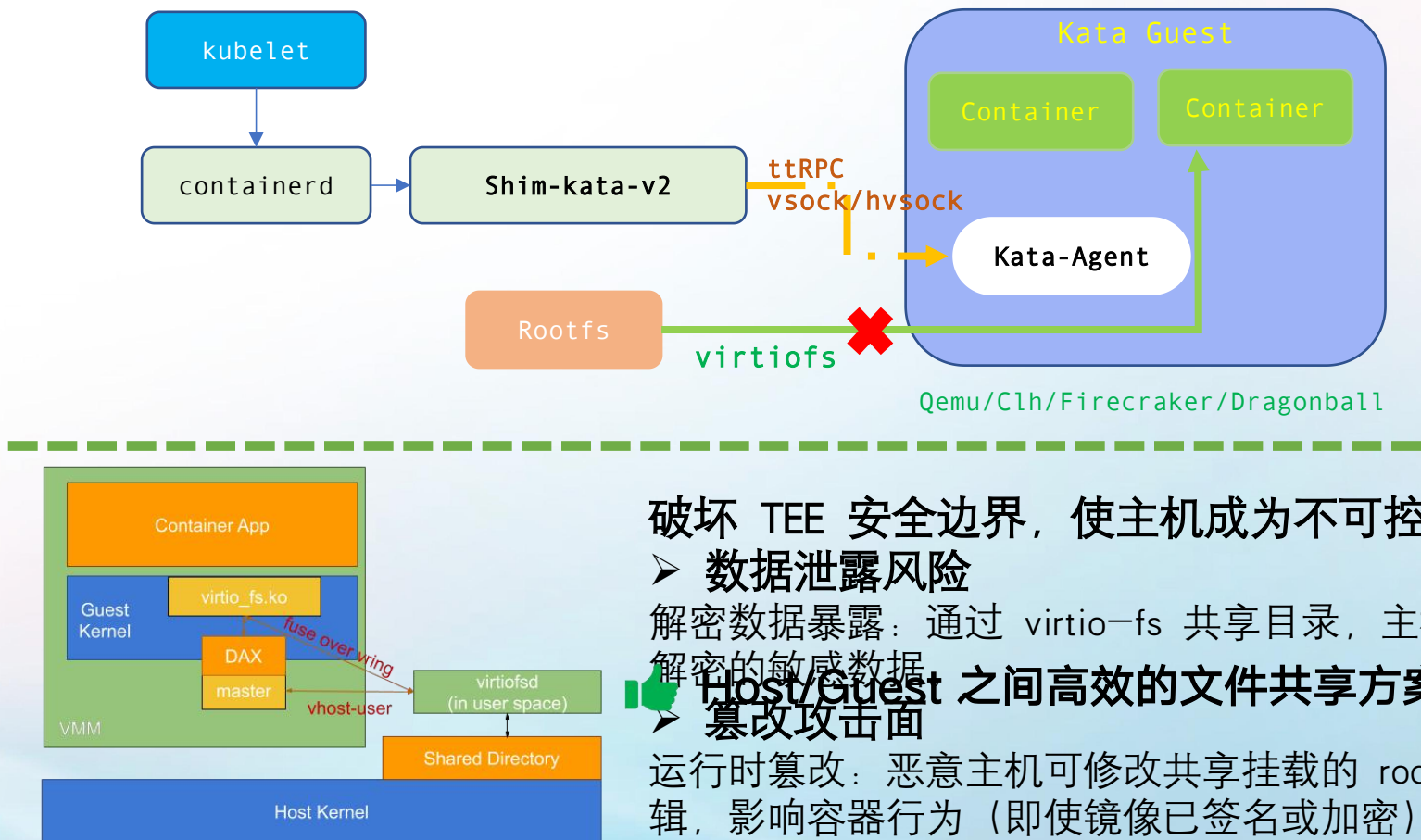
CoCo 作为演进 (CoCo as Evolution)

- 建立在 Kata Containers 之上。
- 新增全栈加固技术：TEEs（可信执行环境）、端到端加密、测量、认证等。
- 保护数据免受源自宿主机的未经授权的访问和篡改。



The Next Layer of Cloud Security

virtio-fs between Host / Guest



破坏 TEE 安全边界，使主机成为不可控攻击面：

➤ 数据泄露风险

解密数据暴露：通过 virtio-fs 共享目录，主机可直接访问客户机内解密的敏感数据

Host/Guest 之间高效的文件共享方案

➤ 篡改攻击面

运行时篡改：恶意主机可修改共享挂载的 rootfs，注入恶意代码或逻辑，影响容器行为（即使镜像已签名或加密）。

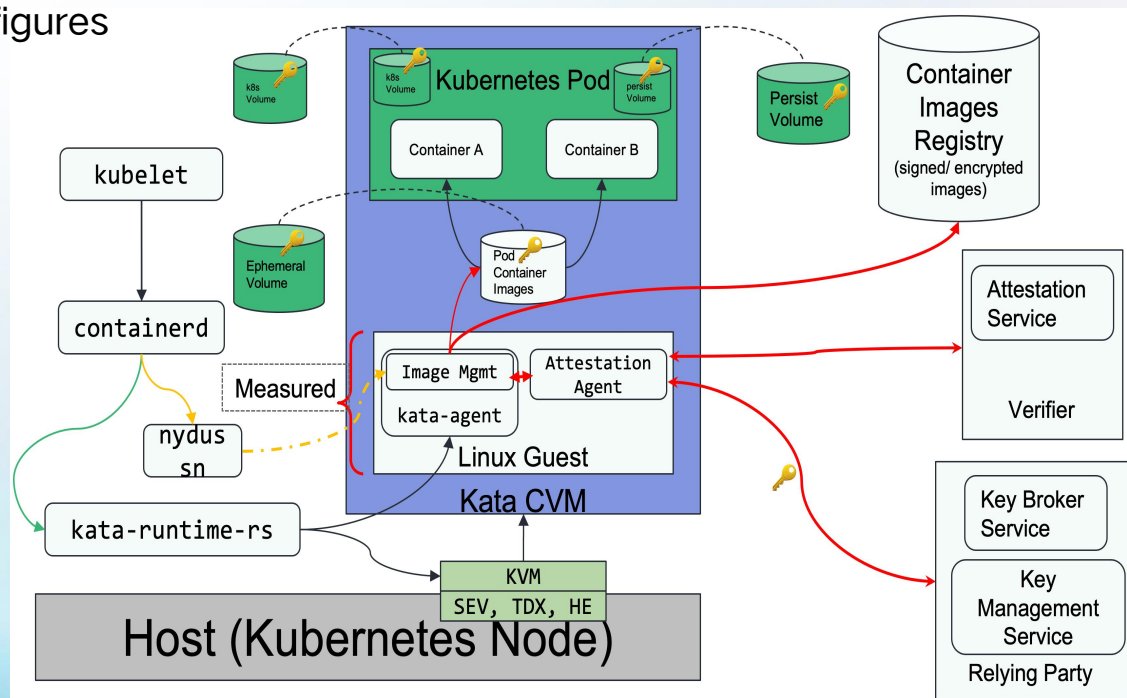
Full CoCo Support in Runtime-rs

How Runtime-rs Enables Kata CVM

- **Core CoCo Features**
- ✓ TEE Hardware: Intel TDX/AMD SEV-SNP/IBM SEL/Ant Group HyperEnclave
- ✓ Guest Image Pulling (remote snapshotter or force-guest-pull)
- ✓ Copyfile for k8s cluster configures

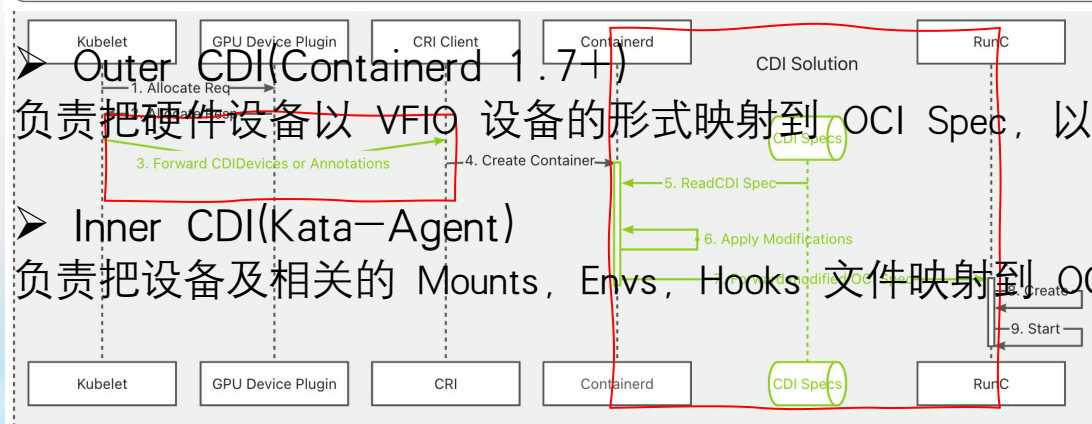
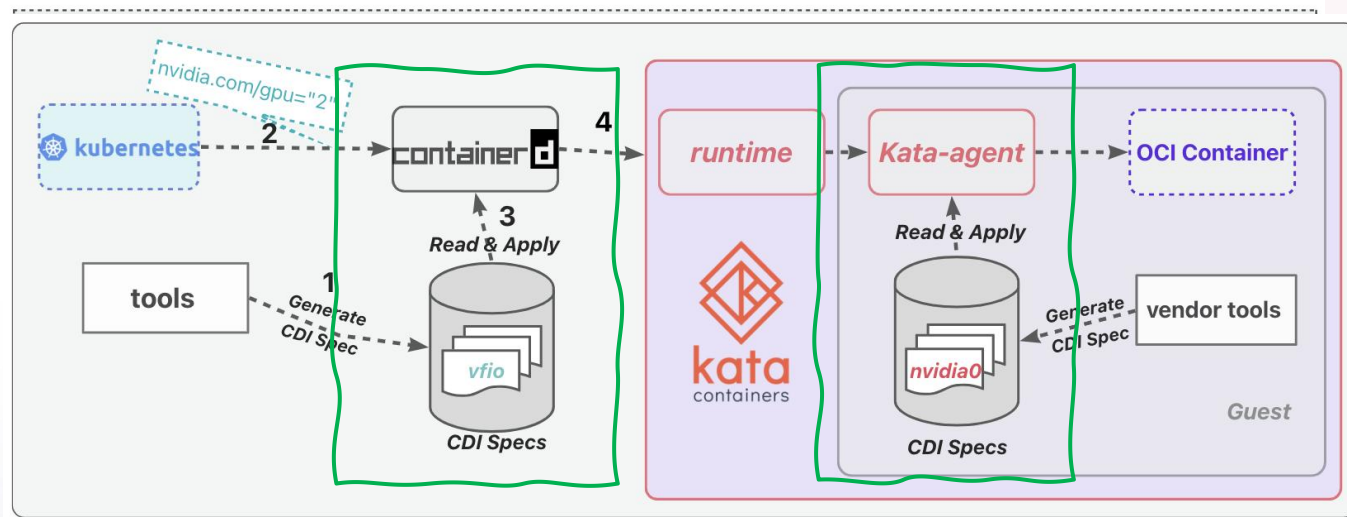
➤ Advanced CoCo Features

- ✓ Initdata Support
- ✓ OPA Agent Policy
- ✓ Trusted Storage
- ✓ Measured Boot
- **Additional Capabilities**
- ✓ Remote Hypervisor
- ✓ Non-TEE Support
- ✓ GPU Device Support



Full CoCo Support in Runtime-rs

Two-tier CDI System for GPU



➤ Outer CDI(Containerd 1.7+)

负责把硬件设备以 VFIO 设备的形式映射到 OCI Spec，以完成设备直通到 Guest 中。

➤ Inner CDI(Kata-Agent)

负责把设备及相关的 Mounts, Envs, Hooks 文件映射到 OCI Spec，使得设备正确暴露给容器。

Full CoCo Support in Runtime-rs

Beyond Runtime-rs: Complete CoCo Solution

经过证明的可信执行环境(Trusted Execution Environment TEE)

➤ Confidential VM:

如何创建一个数据可用不可见的执行环境?

➤ Measurement/Attestation:

在不可信的环境中, 如何建立信任?

Runtime-rs: CoCo 的坚实基础

- 已成功完成 runtime-rs 的重构和优化, 使其成为理想的选择。
- 完全支持所有必要的 CoCo 特性, 包括对完整的 TEE 硬件的支持。
- Runtime-rs 可以无缝与 CoCo 生态系统组件 (例如 KMS 和 RA) 集成。

CONTENT

目录

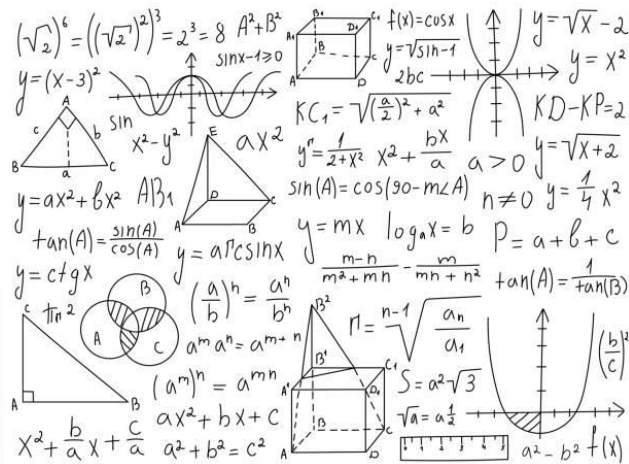
01 机密计算与云原生

02 CoCo机密容器

03 你的数据安全吗？

04 你的运行环境可信吗？

打开隐私保护计算潘多拉魔盒的金钥匙



数学协议、同态加密

理论安全性高、性能较低



机密计算

需要信任硬件厂商、性能几乎无影响

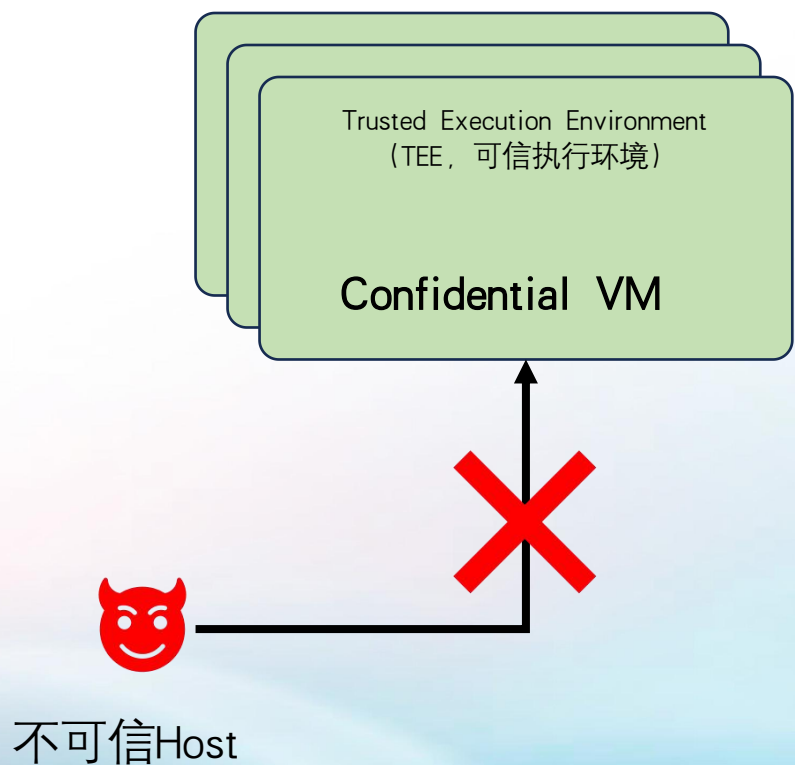


安全多方计算

强分布式隐私、交互带宽
负载高

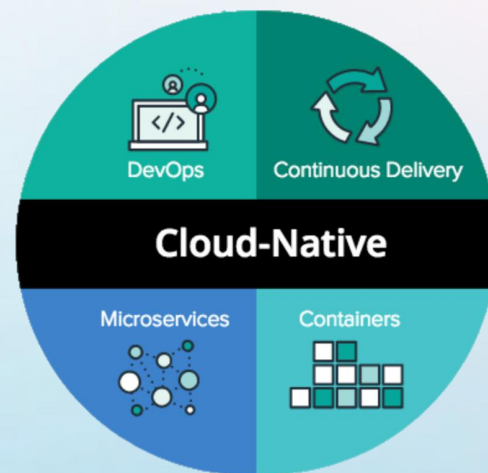
机密计算与云原生

数据安全 + 弹性高可用搭配的绝美盛宴



高可用

弹性扩容

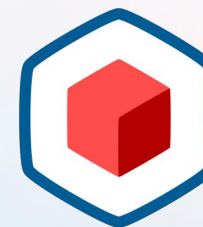
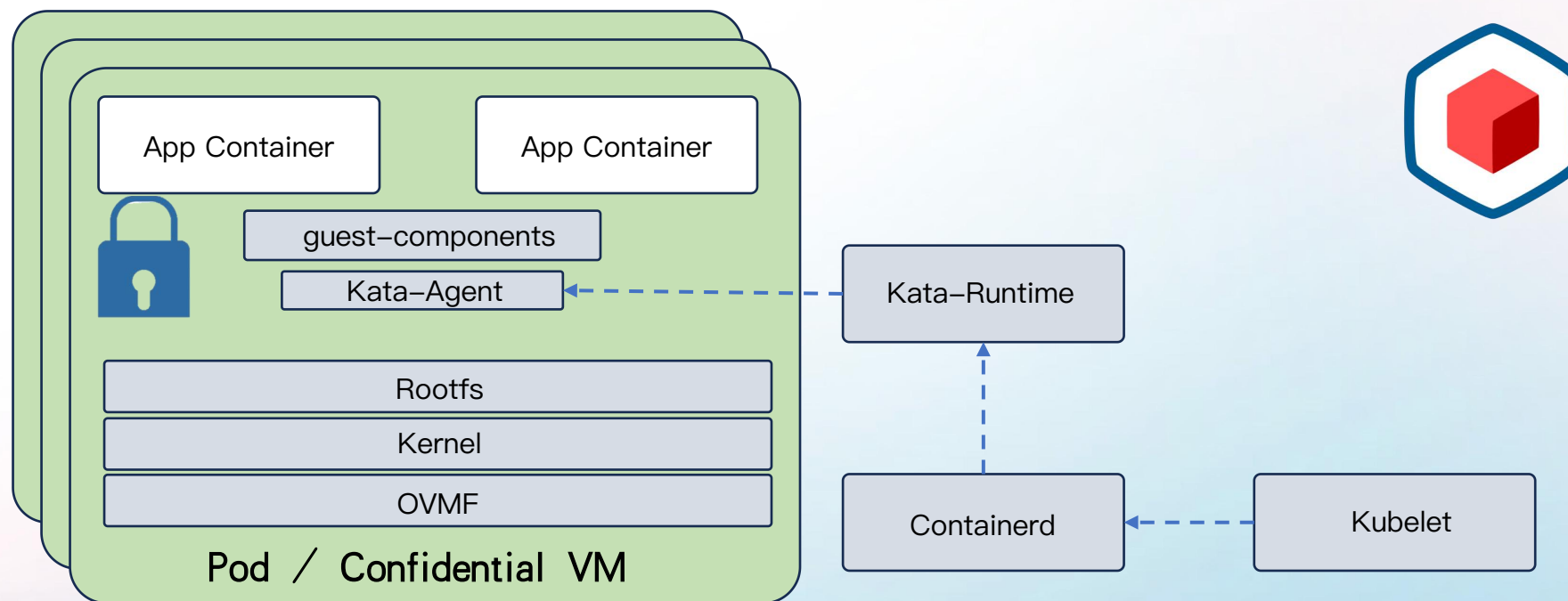


标准化运维

广泛生态支持

Confidential Containers

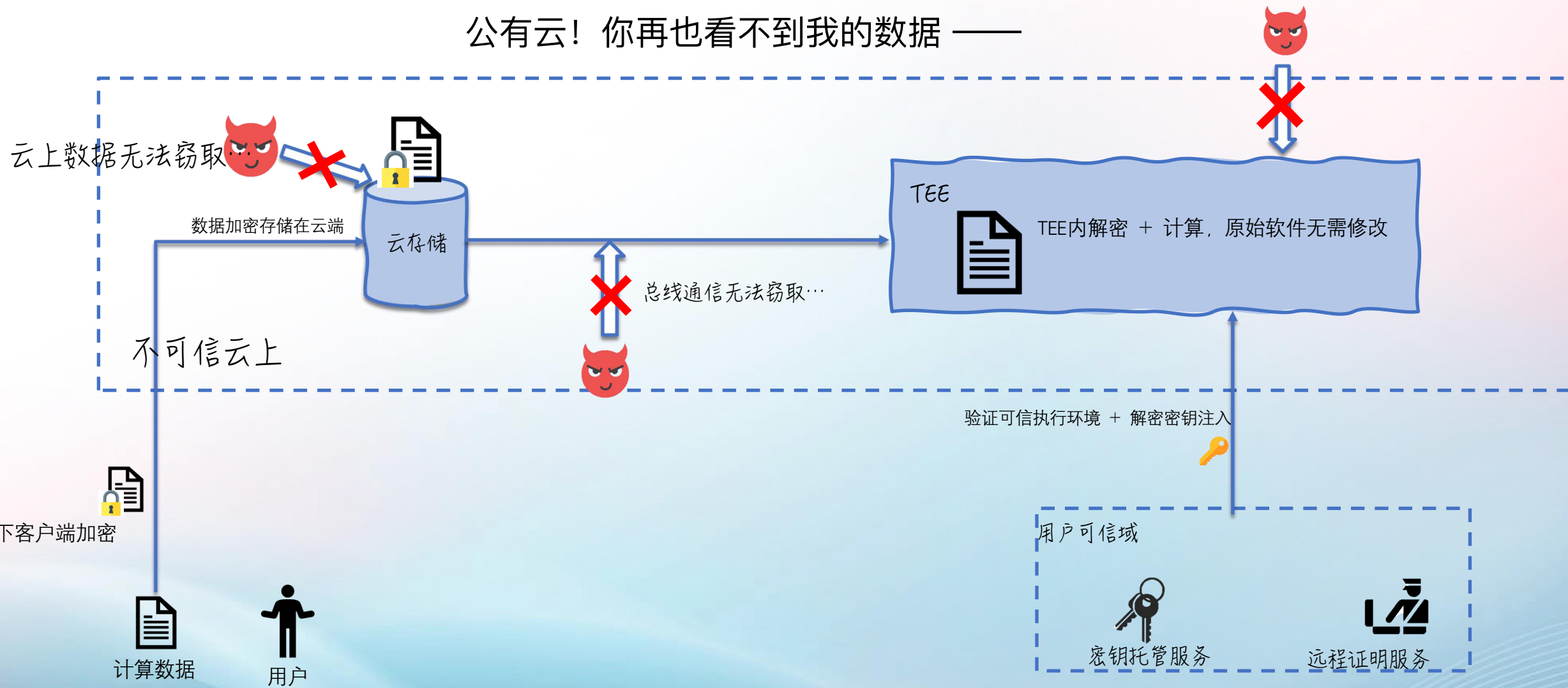
开箱即用的云原生机密容器方案



**CONFIDENTIAL
CONTAINERS**

In-Guest 解密设计范式

公有云！你再也看不到我的数据 ——



镜像数据保护

机密性 + 完整性

TEE内镜像验签+镜像解密



CONFIDENTIAL
CONTAINERS

利用Skopeo对镜像layer镜像加密

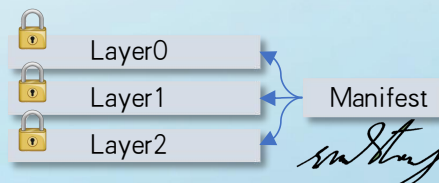
利用Cosign对镜像manifest签名



Manifest



Docker 镜像



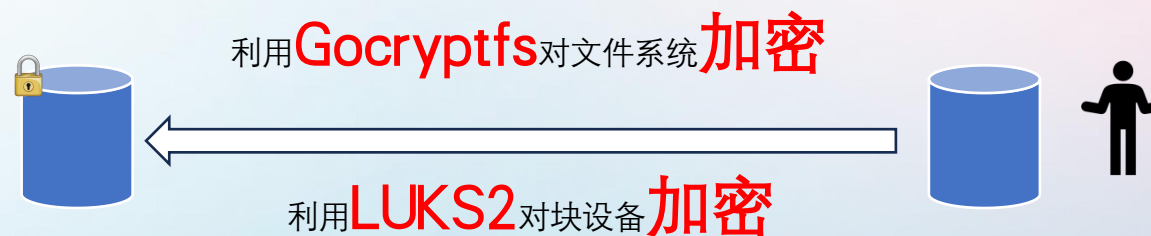
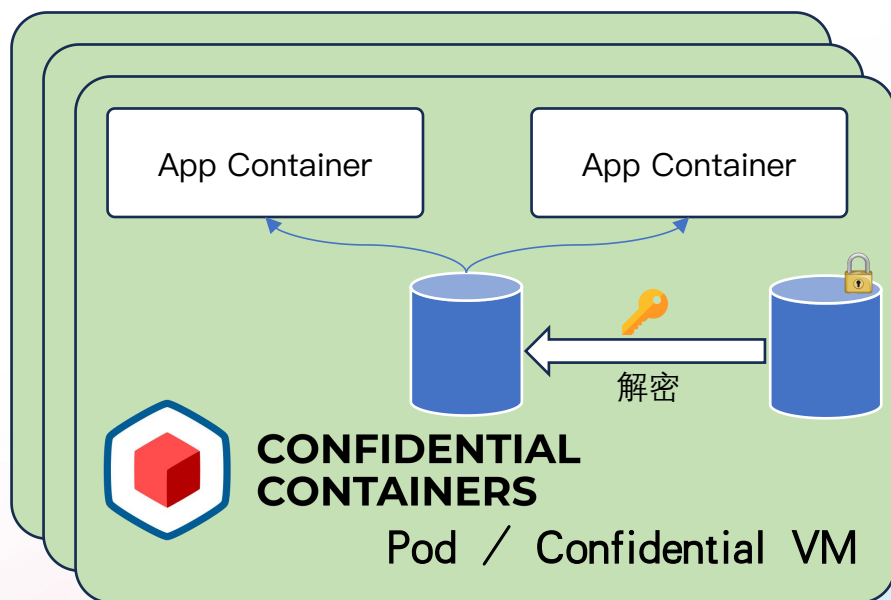
Manifest



Docker Registry

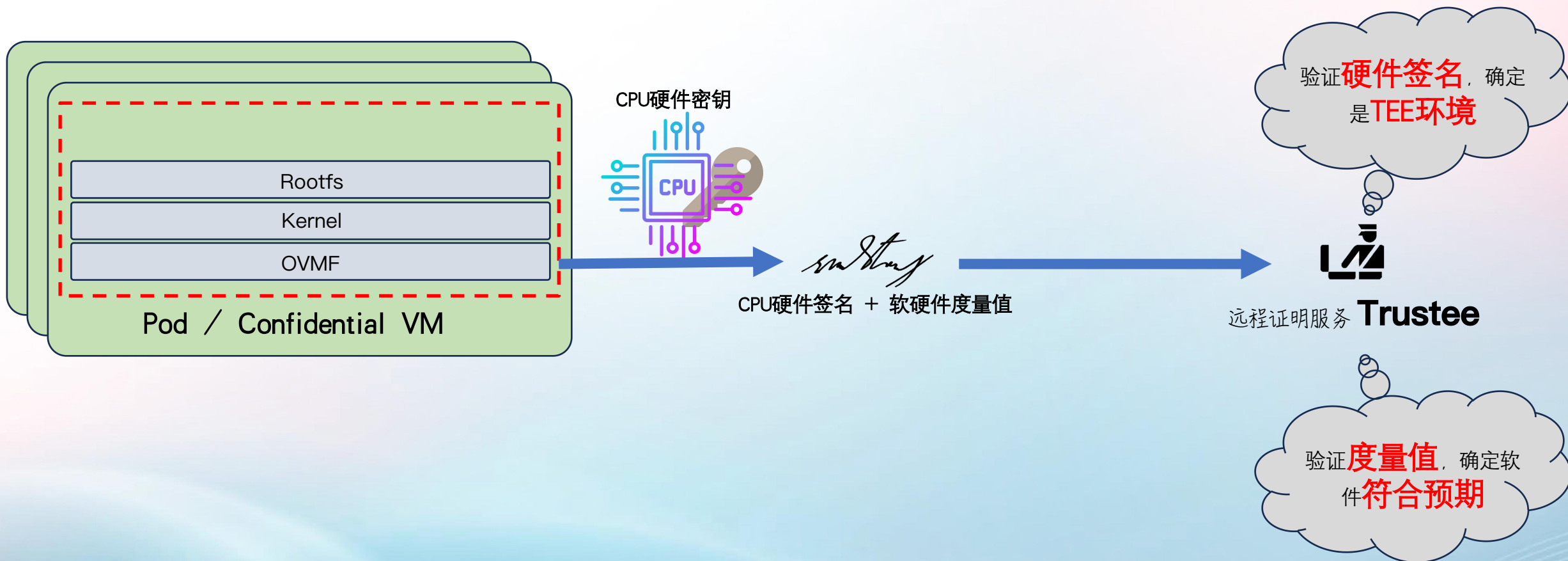
持久化/临时存储数据保护

机密性 + 完整性



远程证明机制

用户：我如何信任环境没问题，并把密钥给你？



远程证明机制

丰富的功能和生态

标准化

远程证明令牌符合IETF 规范定义的
EAT Attestation Result (EAR) 格式

多架构支持

目前支持Intel TDX/SGX、AMD SNP、Arm CCA、海光CSV/DCU、Nvidia GPU、Azure vTPM、TPM等CPU/设备支持

动态度量和组合远程证明

- TCG2兼容格式CoCo Eventlog
- 支持CPU-设备（Nvidia GPU等）证据密码学绑定，规避重放、篡改、伪造等攻击

安全性

Challenge-Response范式的开源RCAR协议，
抗重放攻击等风险

Q & A

